

Data in transit: Nitro, VPC encryption controls, ACM and Private CA

Skill 5.1.3 is new in SCS-C03, and the capability that answers it arrived in November 2025.

A great deal is already encrypted. The exam asks what is **not**, and how you would prove it either way.

What AWS already encrypts for you

- ◆ **Nitro hardware encryption** between supported instance types – **AEAD, 256-bit**, below the OS.
- ◆ **No configuration, no performance impact.** The attribute is **encryptionInTransitSupported**.
- ◆ **Cross-Region traffic** over peering and Cloud WAN is **bulk-encrypted with AES-256** before leaving the Region.
- ◆ **Physical layer AES-256** on links outside AWS's control – those paths are doubly encrypted.
- ◆ **Older instance types do not support it.** Previous-generation means clear traffic.

ON THE EXAM

Nitro encryption is free and invisible – which is why you cannot prove it to an auditor.

VPC encryption controls

- ◆ **Launched November 2025.** Audit and enforce encryption in transit for all traffic within and across VPCs in a Region.
- ◆ **Monitor mode** reports which flows are unencrypted, and quietly migrates certain managed resources to encryption-capable hardware.
- ◆ **Enforce mode** permits only encrypted flows, and **blocks creation or attachment of non-compliant resources.**
- ◆ **Enforce mode needs an internet gateway exclusion,** because IGW traffic leaves the AWS network boundary where the control cannot reach.
- ◆ With Transit Gateway you must **activate encryption controls on the gateway separately.**

ON THE EXAM

AWS names HIPAA, PCI DSS and FedRAMP as the drivers for this control.

Proving it: the encryption-status field

- ◆ **VPC Flow Logs gained an encryption-status field** – Nitro hardware, TLS, both, or neither.
- ◆ Before it, Nitro encryption was invisible and there was no way to demonstrate it.
- ◆ **GetVpcResourcesBlockingEncryptionEnforcement** lists what blocks enforce mode.
- ◆ **NLB, ALB and Fargate migrate automatically** to Nitro hardware, with no interruption.
- ◆ **EC2, ASGs, RDS, ElastiCache, Redshift, EKS, ECS on EC2, MSK, OpenSearch and EMR** need supported instance types.

ON THE EXAM

This closes the module 14 gap: flow logs now say whether a flow was encrypted.

Inter-node encryption, and what is not encrypted

- ◆ **SageMaker AI**: some intranetwork traffic is unencrypted by default, including **between nodes in distributed training and processing jobs**.
- ◆ You can **choose** to encrypt inter-container traffic. AWS names it best practice for healthcare.
- ◆ **It costs you** – increased training time, and therefore cost, for distributed deep learning.
- ◆ **No inter-node communication for batch processing**, so the setting is irrelevant there.
- ◆ **EMR** has its own in-transit setting in a security configuration. **EKS** relies on Nitro instance types.

ON THE EXAM

Distributed ML traffic is in the clear unless you turn it on, and turning it on is not free.

ACM and AWS Private CA

- ◆ **ACM public certificates are free and auto-renewing**, integrating with ELB, CloudFront, API Gateway and App Runner.
- ◆ **DNS validation** renews without human involvement. Email validation does not.
- ◆ **AWS Private CA** issues private certificates – service mTLS, IoT devices, Roles Anywhere, EKS.
- ◆ A hierarchy of root and subordinate CAs, with revocation via **CRL or OCSP**.
- ◆ **Charged per CA per month plus per certificate**. A root CA per team is expensive.

ON THE EXAM

Public certificate for public trust. Private CA for what only your workloads must trust.

Enforcing TLS

- ◆ **aws:SecureTransport** in a resource policy denies any request not made over TLS.
- ◆ **ELB security policies** set minimum TLS version and ciphers on a listener.
- ◆ **CloudFront** – viewer protocol policy, plus a minimum protocol version.
- ◆ **Mutual TLS** on ALB and API Gateway verifies a client certificate too.
- ◆ SecureTransport says TLS was used. It says nothing about **which version**.

ON THE EXAM

SecureTransport is a boolean about the connection. The version lives in the security policy.

PrivateLink and VPC endpoints

- ◆ **Gateway endpoints** for S3 and DynamoDB via a route. **Interface endpoints** for the rest, as an ENI.
- ◆ Traffic **never traverses the public internet** – module 18's primary control for LLM02.
- ◆ **Endpoint policies** restrict which buckets or principals may pass through.
- ◆ Pair with **aws:SourceVpce** to require access arrives through your endpoint.
- ◆ Module 6: requests through an endpoint carry **aws:VpcSourceIp**, not **aws:SourceIp**.

ON THE EXAM

PrivateLink removes the internet from the path. It is not encryption.

A hospital group must demonstrate to an auditor that traffic between its EC2 instances inside a VPC is encrypted in transit. The instances are current-generation types and the team believes Nitro hardware encryption applies, but cannot produce evidence.

The auditor will not accept an architecture diagram or a statement that AWS encrypts it. Application-level TLS is not implemented between these particular services.

What should the group use?

- A VPC Flow Logs with the encryption-status field, showing each flow's encryption state
- B A packet capture on one instance, demonstrating the traffic is unreadable
- C AWS Config rules confirming the instances are Nitro-based types
- D An ACM certificate on an internal load balancer between the services

◆ PAUSE AND DECIDE

What should the group use?

- A

Flow Logs with the encryption-status field

Correct. It reports per flow whether encryption came from Nitro hardware, TLS, both or neither - which is evidence about actual traffic rather than about configuration.
- B

Packet capture on the instance

Nitro encryption happens in the Nitro card, below the operating system. A capture taken on the instance sees the traffic before encryption, so it would appear unencrypted.
- C

Config rules confirming instance types

Proves the instances are capable, which is necessary and not sufficient. It says nothing about whether any particular flow was encrypted.
- D

ACM certificate on an internal load balancer

Would genuinely add TLS and re-architects the application to answer an evidence question. It also does not prove anything about the existing flows.

THE SIGNAL

Option B is the instructive one. Encryption below the OS means the host is exactly the wrong place to look for it.

A healthcare analytics company runs distributed SageMaker AI training jobs across multiple instances, using de-identified but still sensitive patient data. A security review asks whether the data is encrypted as it passes between the training nodes.

The team's answer is that SageMaker encrypts everything by default. The reviewer wants that verified.

What is true, and what should the team do?

- ☐ A SageMaker encrypts all traffic by default; document it and close the finding
- ☐ B Use Nitro-based instance types, which encrypts inter-node training traffic automatically
- ☐ C Move the training data to S3 with SSE-KMS, which covers it in transit as well
- ☐ D Inter-node traffic in distributed training is not encrypted by default; enable inter-container traffic encryption

◆ PAUSE AND DECIDE

What is true, and what should the team do?

- A

 SageMaker encrypts everything by default
The team's assumption, and AWS documentation contradicts it explicitly: some intranetwork traffic, including between nodes in distributed training jobs, is unencrypted.
- B

 Nitro instance types cover it automatically
The strongest distractor. Nitro encryption is real and applies between EC2 instances - the documented SageMaker setting exists precisely because the platform's inter-container path needs enabling.
- C

 SSE-KMS on S3 covers it
Confuses at rest with in transit. SSE-KMS protects objects in S3; it says nothing about data moving between training nodes.
- D

 Not encrypted by default; enable inter-container traffic encryption
Correct. AWS names this as best practice for healthcare, and states the trade honestly - it can increase training time and cost.

THE SIGNAL

AWS documents exactly what is not encrypted. 'Encrypted by default' is a reasonable assumption that the documentation contradicts.

A bank enables VPC encryption controls in monitor mode, reviews the findings, and switches to enforce mode across a production VPC. Immediately, all outbound traffic to the internet through the internet gateway fails.

Internal traffic between instances continues normally. Traffic across the Transit Gateway to other VPCs also fails.

What should the bank do?

- ☐ A Revert to monitor mode; enforce mode is incompatible with internet access
- ☐ B Add an internet gateway exclusion, and activate encryption controls on the Transit Gateway
- ☐ C Replace the internet gateway with a NAT gateway, which supports encrypted flows
- ☐ D Enable Nitro encryption on the internet gateway

◆ PAUSE AND DECIDE

What should the bank do?

- A Revert; enforce mode cannot coexist with internet access

Overreads it. The exclusion exists precisely so the two can coexist - reverting abandons the control the bank deliberately adopted.

- C Swap the IGW for a NAT gateway

A NAT gateway still sends traffic out through an internet gateway. The boundary problem is unchanged, and the design has been altered for nothing.

- B IGW exclusion, and activate controls on the Transit Gateway

Correct. Both symptoms are documented requirements: IGW traffic leaves the AWS boundary, and a Transit Gateway must have encryption controls activated separately.

- D Enable Nitro encryption on the IGW

Nitro encryption applies between instances. An internet gateway is not an instance, and there is no such setting on it.

THE SIGNAL

Two distinct symptoms, two documented requirements. The scenario names both, and only one option addresses both.

A payments company runs 200 internal microservices that must authenticate each other with mutual TLS. Certificates must be trusted only within the company's own estate, must be revocable individually, and must be issuable automatically as services are deployed.

An engineer proposes requesting a public certificate from ACM for each service.

What should the company use instead?

- A A single wildcard public ACM certificate shared by all 200 services
- B Self-signed certificates distributed by the configuration management system
- C AWS Private CA, with a root and subordinate CAs issuing per-service certificates
- D IAM Roles Anywhere, which issues certificates to each service

◆ PAUSE AND DECIDE

What should the company use instead?

- A

 One shared wildcard public certificate
Repeats the module 13 lesson in a new setting – a shared credential cannot be revoked for one holder, and 'trusted only internally' rules out a public certificate anyway.
- B

 Self-signed certificates via config management
Workable and it means building and operating a PKI by hand: distribution, rotation, revocation and trust stores across 200 services.
- C

 AWS Private CA with a root and subordinate CAs
Correct. Private trust only, per-service certificates revocable individually via CRL or OCSP, and automatic issuance as services deploy.
- D

 IAM Roles Anywhere
Consumes certificates from a CA to grant AWS credentials to external workloads. It is not a certificate authority, and this is service-to-service mTLS rather than AWS access.

THE SIGNAL

'Trusted only within our estate' rules out public certificates by definition. 'Revocable individually' rules out anything shared.

Six things to carry forward

- ◆ Nitro encrypts below the OS – a packet capture on the host shows plaintext.
- ◆ The Flow Logs encryption-status field is how you prove it.
- ◆ Enforce mode needs an IGW exclusion; a Transit Gateway is activated separately.
- ◆ SageMaker distributed training is not encrypted by default, and enabling it costs time.
- ◆ aws:SecureTransport says TLS was used, not which version.
- ◆ Public certificate for public trust. Private CA for internal mTLS.

ON THE EXAM

Next: secrets and masking – Secrets Manager, Parameter Store, and redaction at source.